

Stockage de Fichiers Sécurisé

PHP 8 · PostgreSQL · OpenSSL

1. Présentation du projet

L'application est un service de stockage de fichiers en ligne sécurisé développé en PHP 8 avec PostgreSQL. Elle permet à des utilisateurs authentifiés de téléverser, télécharger et partager des fichiers tout en garantissant leur confidentialité grâce à un chiffrement bout-en-bout. L'interface est volontairement minimaliste (HTML/CSS pur).

2. Fonctionnalités implémentées

2.1 Gestion des utilisateurs

À l'inscription, une paire de clés RSA-2048 est générée automatiquement pour chaque utilisateur. La clé privée est chiffrée avant stockage (voir §3.3). La connexion régénère l'identifiant de session pour prévenir la fixation de session. La suppression de compte efface en cascade tous les fichiers et partages associés.

2.2 Upload et stockage

- **Génération** d'une clé AES-256 aléatoire unique par fichier.
- **Chiffrement** du contenu, du nom original et du type MIME avec AES-256-GCM (jamais stockés en clair).
- **Stockage** sous un nom hexadécimal aléatoire de 64 caractères (nom original non devinable).
- La **clé AES** est chiffrée avec la clé publique RSA du propriétaire et insérée dans la table partager.

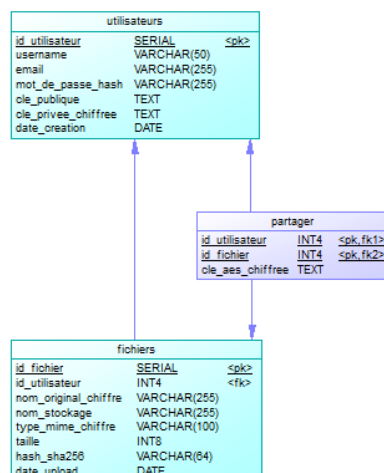
2.3 Téléchargement

Le serveur vérifie que l'utilisateur a un accès (propriétaire ou partage), déchiffre la clé AES via RSA, déchiffre le fichier avec AES-256-GCM, vérifie le hash SHA-256 d'intégrité, puis envoie le fichier au navigateur.

2.4 Partage sécurisé (enveloppe numérique)

La clé AES du fichier est déchiffrée par le propriétaire via sa clé privée RSA, puis re-chiffrée avec la clé publique RSA du destinataire. Chaque utilisateur ayant accès possède sa propre entrée dans la table partager avec la clé AES chiffrée pour lui — la clé AES n'est jamais exposée en clair.

3. Mécanismes de sécurité



3.1 Mots de passe — Argon2id

Les mots de passe sont hachés avec Argon2id via `password_hash()` (algorithme recommandé par l'OWASP pour sa résistance aux attaques GPU et force brute). Le sel est généré et intégré automatiquement dans le hash. Le mot de passe en clair est conservé en session PHP uniquement pour déchiffrer la clé privée RSA à la volée.

3.2 Chiffrement des fichiers — AES-256-GCM

AES-256-GCM est un chiffrement authentifié (AEAD) qui garantit simultanément la confidentialité et l'intégrité. Un IV de 16 octets aléatoire est généré à chaque opération. Le tag GCM (16 octets) permet de détecter toute altération du fichier chiffré.

Format sur disque : IV (16 o) || Tag GCM (16 o) || Données chiffrées

3.3 Protection de la clé privée RSA — PBKDF2 + AES-256-GCM

La clé privée RSA est chiffrée avant stockage en base : la clé de chiffrement est dérivée du mot de passe via PBKDF2-SHA256 (100 000 itérations, sel aléatoire 16 o), puis AES-256-GCM chiffre la clé PEM. Même un accès complet à la base ne permet pas de récupérer les clés privées sans connaître les mots de passe.

Format en base : Base64(Sel || IV || Tag || Clé PEM chiffrée)

3.4 Enveloppe numérique — RSA-2048 OAEP

La clé AES symétrique est chiffrée avec la clé publique RSA-2048 du destinataire en utilisant le padding OAEP (plus sûr que PKCS#1 v1.5). Chaque partage crée une nouvelle entrée avec la clé AES re-chiffrée pour ce destinataire.

3.5 Intégrité — SHA-256

Un hash SHA-256 du contenu original est calculé à l'upload et stocké en base. Au téléchargement, le hash est recalculé après déchiffrement et comparé : toute modification du fichier chiffré est immédiatement détectée (le tag GCM d'AES-256-GCM constitue également une vérification d'intégrité).

3.6 Contrôle d'accès et protections web

Menace	Contre-mesure
Vol de la base de données	Hash Argon2id + fichiers AES-256-GCM + clés privées PBKDF2+AES-GCM
Accès non autorisé (IDOR)	Vérification propriétaire/partage en base sur chaque requête
Injection SQL	Requêtes préparées PDO avec paramètres nommés
XSS	<code>htmlspecialchars()</code> systématique sur toutes les sorties HTML
Fixation de session	<code>session_regenerate_id()</code> à la connexion
Altération de fichier	Hash SHA-256 + tag GCM vérifiés au téléchargement
Accès direct aux fichiers	Nom de stockage hexadécimal aléatoire (64 car.)

